UNIT 5 · TOPIC 5.6

Application Threat Auditing

Quiz

Instructions: This quiz has 18 multiple-choice questions, 1 point each. Circle the letter of the single best answer for each question.

Name: **Date:** **Class:**

1. Which of the following BEST describes the purpose of a file integrity monitoring (FIM) system?

- ○ A. A firewall rule set that prevents unauthorized write access to protected directories
- ○ B. A tool that detects changes to files by comparing their current cryptographic hashes against a recorded baseline
- ○ C. An antivirus scanner that removes malware found inside system files
- ○ D. A backup utility that creates periodic snapshots of critical data directories

2. A security analyst downloads a software package from a vendor's website. Before installation, the analyst wants to verify the package has not been tampered with during transit. Which action BEST achieves this?

- ○ A. Compare the SHA-256 hash of the downloaded package against the hash published on the vendor's official site
- ○ B. Run the installer inside a sandboxed virtual machine before deploying to production
- ○ C. Verify that the file extension matches the expected package type
- ○ D. Scan the package with a network-based intrusion detection system prior to installation

3. Which type of log is MOST directly useful for detecting unauthorized access attempts against a web application?

- ○ A. System boot log
- ○ B. DHCP lease log
- ○ C. Web server access log
- ○ D. Hardware event log

4. An organization wants to detect SQL injection attempts against its customer portal in real time. Which control is MOST appropriate?

- ○ A. Deploying a web application firewall (WAF) configured with SQL injection detection signatures
- ○ B. Encrypting the database at rest using AES-256
- ○ C. Enforcing multi-factor authentication for all database administrators
- ○ D. Applying role-based access control to database tables

5. A financial institution must detect when sensitive data files are being exfiltrated through its internal network. Which detection control BEST addresses this requirement?

- ○ A. An endpoint encryption agent that automatically encrypts all outbound files
- ○ B. A backup system that archives all files to an offline location daily
- ○ C. A network firewall rule blocking all outbound traffic on port 443
- ○ D. A data loss prevention (DLP) system configured with policies for sensitive data patterns such as account numbers and PII

6. Which combination of controls provides the MOST comprehensive detection coverage for attacks against an application's data layer?

- ○ A. Database activity monitoring (DAM) and file integrity monitoring (FIM)
- ○ B. Antivirus software and a host-based firewall
- ○ C. Role-based access control and full-disk encryption
- ○ D. VPN tunneling and multi-factor authentication

7. A CISO is evaluating whether to deploy network-based intrusion detection (NIDS) or host-based intrusion detection (HIDS) to detect attacks against application data. Which assessment BEST captures the operational trade-off between the two approaches in a TLS-encrypted environment?

- ○ A. NIDS is always preferable because it requires no agents on endpoints and provides perimeter-wide coverage.
- ○ B. HIDS provides granular visibility into file and process activity on individual hosts; NIDS cannot inspect application-layer content after TLS termination occurs inside the host.
- ○ C. HIDS should always be chosen because network traffic inspection violates user privacy law in most jurisdictions.
- ○ D. NIDS and HIDS are functionally identical for this use case; the choice is purely one of deployment convenience.

8. An organization deploys file integrity monitoring but configures it to alert on ALL file changes, including OS patch installations, application log rotation, and temporary cache writes. Which consequence is MOST likely to undermine the detection strategy?

- ○ A. The FIM system will be unable to compute valid hashes for files that have been updated by the patch manager.
- ○ B. Security analysts will experience alert fatigue, reducing the probability that genuine tampering events receive timely investigation.
- ○ C. Application log files will be automatically excluded from FIM coverage by the operating system.
- ○ D. The organization will automatically satisfy NIST SP 800-53 continuous monitoring requirements.

9. A security architect is comparing two detection strategies for application attacks: signature-based detection and anomaly-based detection. Which evaluation MOST accurately characterizes the inherent trade-offs of each approach?

- ○ A. Signature-based detection is superior because well-maintained rule sets produce zero false positives by definition.
- ○ B. Anomaly-based detection is always preferable because signatures become outdated the moment a new attack variant is released.
- ○ C. Both methods produce identical detection rates and false positive rates because they process the same underlying log data.
- ○ D. Signature-based detection reliably identifies known attack patterns with low false positives but fails against novel or obfuscated techniques; anomaly-based detection can surface unknown attacks but generates elevated false positives during initial baseline establishment.

10. A security analyst computes the SHA-256 hash of a critical system configuration file and records the value as a baseline. One week later, the analyst recomputes the hash of the same file and finds the value has changed. What does this indicate?

- ○ A. The SHA-256 algorithm has weakened over time, producing inconsistent outputs for identical input.
- ○ B. The configuration file's contents have been modified since the baseline was recorded.
- ○ C. The file system automatically compressed the file to recover disk space, altering the stored bytes.
- ○ D. The analyst selected a different hash algorithm for the second computation, producing a different output length.

11. Which of the following entries in a web application access log is MOST likely an indicator of a directory traversal attack?

- ○ A. GET /images/logo.png HTTP/1.1 200
- ○ B. POST /api/login HTTP/1.1 401
- ○ C. GET /../../etc/passwd HTTP/1.1 403
- ○ D. GET /index.html HTTP/1.1 304

12. A SOC receives an alert stating that an executable on a production web server has a SHA-256 hash that does not match the value published by the software vendor. Which classification BEST describes this finding?

- ○ A. An indicator of compromise (IoC) suggesting the file may have been replaced or backdoored
- ○ B. A false positive caused by antivirus software quarantining part of the file
- ○ C. An expected result of operating system localization adapting the binary for the regional environment
- ○ D. A routine outcome when software is updated through an automated patch management system

13. An analyst reviews the following Apache access log entries:

192.168.10.44 - - [04/Jul/2026:14:22:01] "GET /admin/config.php HTTP/1.1" 200 4821
192.168.10.44 - - [04/Jul/2026:14:22:03] "GET /admin/users.php HTTP/1.1" 200 9342
192.168.10.44 - - [04/Jul/2026:14:22:05] "POST /admin/users.php HTTP/1.1" 200 512
192.168.10.44 - - [04/Jul/2026:14:22:08] "GET /admin/backup.php HTTP/1.1" 200 1284

Which attack behavior do these log entries MOST likely indicate?

- ○ A. A brute-force credential stuffing attack targeting the admin login page
- ○ B. A legitimate administrator performing routine site maintenance tasks
- ○ C. An attacker systematically enumerating and interacting with administrative pages after gaining unauthorized access
- ○ D. A denial-of-service attack consuming server resources through repeated HTTP requests

14. A log analysis platform flags 4,000 failed database queries from the application server within 30 seconds. Each flagged query contains the SQL fragment `UNION SELECT`. Which attack class is MOST consistent with this pattern?

- ○ A. A cross-site scripting (XSS) attack injecting malicious scripts through the database
- ○ B. A UNION-based SQL injection attack attempting to extract data by appending attacker-controlled SELECT statements
- ○ C. A denial-of-service attack aimed at exhausting the database connection pool through query flooding
- ○ D. A brute-force attack cycling through common database user passwords

15. Application event logs show that a service account named `svc_backup`, normally active only between 02:00 and 04:00 UTC, is generating authentication events continuously from 11:00 to 23:00, accessing files outside its usual backup directories. Which detection technique BEST classifies this behavior?

- ○ A. Behavioral anomaly analysis comparing observed account activity against its established baseline
- ○ B. Signature-based detection using a known malware hash database
- ○ C. Port scanning to enumerate which services the account is communicating with externally
- ○ D. Vulnerability scanning of the backup server to identify exploitable weaknesses

16. A SOC is evaluating two detection approaches: (1) a traditional SIEM with manually authored correlation rules, and (2) an AI-powered behavioral analytics platform that models normal application traffic to surface

anomalies. A senior analyst asks which system is expected to produce a higher false positive rate during the first 30 days of deployment. Which response BEST reflects the documented trade-off?

- ○ A. Both systems will have identical false positive rates because they analyze the same underlying log stream.
- ○ B. The traditional SIEM, because manually authored correlation rules are known to generate more alerts than AI systems in every deployment scenario.
- ○ C. The AI platform, because it requires a learning period to establish baselines and will initially flag many legitimate behaviors as anomalous.
- ○ D. Neither system will produce false positives; false positives only arise in antivirus systems and are not a property of SIEM or AI analytics platforms.

17. A forensic analyst investigating an incident finds the following evidence: (1) web application logs showing repeated HTTP 500 errors triggered by requests containing a single-quote character; (2) a database audit log recording queries with `OR '1'='1'` appended to WHERE clauses; (3) a timestamped export file of the full users table created during the incident window. Which conclusion BEST integrates all three evidence streams?

- ○ A. The server experienced a routine database connectivity failure unrelated to external input.
- ○ B. An XSS attack succeeded in stealing session cookies, giving the attacker read access to the users table.
- ○ C. The HTTP 500 errors indicate a denial-of-service attack; the database queries were generated by an unrelated internal maintenance process.
- ○ D. A SQL injection attack was successfully executed, resulting in authentication bypass and data exfiltration from the users table.

18. An organization's AI-powered anomaly detection system fails to alert on a sophisticated attacker who spent three months studying the organization's normal application behavior before acting, then deliberately constrained their malicious activity to remain within the established behavioral baseline. Which limitation of AI-assisted detection does this scenario MOST directly illustrate?

- ○ A. AI detection systems process log data more slowly than human analysts, creating a detection lag.
- ○ B. AI detection systems require explicit human approval before classifying any event as malicious.
- ○ C. AI behavioral models can be evaded by adversaries who perform reconnaissance to understand and then mimic the established baseline pattern.
- ○ D. Anomaly detection is fundamentally ineffective against all cyberattacks and should be fully replaced with signature-based detection.